Attaques par Dictionnaire : ou wordlist attaque on utilise une liste de mot des mots de passes les plus probables et/ou les plus commun on les compares au hash cible et si les deux hashs correspondent c'est craché, cet technique a ses limites mais est idéale lorsque l'on opère avec la contrainte du temps (CTF, Pentest...)

John The Ripper :

John The Ripper est un outil de pentest bien connu utilisé pour casser les mot de passe par le biais de diverses attaques notamment par bruteforce et dictionnaire

- Le mode single crack : une technique de cassage basé sur des règles particulièrement utile pour cibler les identifiants linux il génère des mot de passes candidats en se basant sur le nom d'utilisateur, et autres valeurs du champ GECOS (nom complet, num de bureau, de telephone etc) au format standard linux (/etc/passwd) - Donc en gros on donne a jhone dans un fichier la ligne passwd structuré avec 7 champs séparés par (:).
Example rolf : 6 hash_ici : 0:0: Rolf Sébastian : /home/rolf : /bin/bash.
Jhone va en extraire automatiquement les informations personnelles (mots ancre) leurs appliquer plusieurs modification mathématique et génèrer ainsi une liste de mots de passe sur mesure.
Ex d'utilisation sur un fichier : Agentpathogène@parrot ~$ jhon --single passwd

- Le mode wordlist : utilisé pour les attaques par dictionnaire
Example : Agentpathogene@parrot ~$ john --wordlist=/path/to/wordlist hash_file

- Le mode incrémental : mode de cassage puissant de type force-brute, gourmand en ressources et plutot lent, il est plus efficace que les attaques brute force naive, il génère des mot de pass candidats sur un modèle statistique (Chaine de Hackrov) il est conçu pour tester toute les combinaisons de caractères définis par un jeu de caractère spécifique en priorisant les mot de passe les plus probables sur la base de données d'entrainement. Les modes incrementaux predefinis sont spécifiés dans son dossier de configuration. /etc/john/john.conf Example ~$ john --incremental hash_file

Casser des fichiers : il est également possible de casser des fichiers protégés par mot de passe ou chiffré avec plusieurs outils "2 john" fournit avec John The Ripper, localisables avec locate "2 john"

- Pour voir le format d'un hash et son format JTR correspondant :
Agentpathogène@parrot ~$ hashid -j hashanalyser
Ensuite pour préciser le format a JTR : --format=nomduformatjohn.

Introduction à Hashcat :

Hashcat est un outil de craquage de hash bien connu pour linux, Windows et macOS. Personnellement je le trouve plus efficace que John.
La syntaxe générale se décompose ainsi :

Agentpathogene@parrot ~$ hashcat -a 0 -m 0 hash_file [wordlist, rules, mask]
-a : utilisé pour spécifier le mode d'attaque (attack mode)
-m : utilisé pour spécifier le type de hash (hash_type) /!\ du même type
hash_file : soit une chaine de hashage soit un fichier en contenant un ou plusieurs
[wordlists, rules, mask] : espace reservés avec arguments supplementaires qui dépendent du mode d'attaque.

- Hashcat prend en compte des centaines de types de hashage différent chaqun se voyant attribuer un ID (md5 c'est 0 sha256 c'est 1400) la liste est affichable avec : hashcat --help ou alternativement pour trouver le HashID d'une chaine de hashage :
Agentpathogène@parrot ~$ hashid -m 'Chainedehashage'